



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Computer Security COMP SCI 4610-101 2026 Spring Semester

About Instructor



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Dr. Junjie Xiong,
 - Office: CS Building 316
 - Phone: 813-291-8472
 - Email: junjiexiong@mst.edu
 - URL: <https://junjiexiong.site>
 - Office hour:
 - Tuesday, 1:00 pm - 2:00 pm;
 - Thursday, 1:00 pm - 3:00 pm,
 - or by appointment.
 - Class meetings:
 - **Tu Th 9:30AM -10:45AM (Computer Science 00121)**

About Teaching Assistant



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Yuanbo Zhou,**
 - Office: CS Building 101
 - Email: yztpn@mst.edu
 - Office hour:
 - Tuesday, 2:00 pm - 3:00 pm;
 - Thursday, 3:00 pm - 4:00 pm,
 - or by appointment.

Prerequisites



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Prerequisites: A grade of "C" or better in Comp Sci 3610. ***Introduction to Computer Networks***

Textbook



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Suggested textbook
 - Neil Daswani, Christoph Kern, and Anita Kesavan, *Foundations of Security, What Every Programmer Needs to Know, 1st Edition*, Apress, ISBN: 0-13-046019-2. ISBN-10: 1590597842; ISBN-13: 978-1590597842
 - E-copy of this book can be downloaded from MST library.

Grading



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- 2 Projects: 20% (**Please bring your PC; buffer overflow && SQL injection**)
- 4 Assignments 30%
- 10+ Quizzes 5%
- Midterm 20% (**1-page A4 cheat-sheet is allowed**) closed-book
- Final 25% (**1-page A4 cheat-sheet is allowed**) closed-book
- The final grades are computed according to the following rules:
 - A: [90.00 - 100] %
 - B: [80.00 - 90) %
 - C: [70.00 - 80) %
 - D: [60.00 - 70) %
 - F: < 60 %

Policies on incomplete grades and late assignments



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Homework and project deadlines will be hard.
- Late homework will be accepted with a 10% reduction in grade each day they are late by.
- Once a homework assignment is discussed in class, submissions will no longer be accepted.

Policies on Absences and Scheduling Makeup Work



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Make-up exams will not normally be permitted. Exceptions will be made if a student presents a police report or a doctor's note that show some emergency.
- Events such as going on a business trip or attending a brother's wedding are not an acceptable excuse for not taking an exam at its scheduled time and place.

Policies on academic integrity



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- An FF grade will be assigned to a student who is caught cheating for this class. Example cheating behaviors include but not limited to direct and indirect plagiarizing another student's work or online resources or modifying incorrect test and homework answers for regrading.

Access and Concerns



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- In-person class, no recording will be provided.
- In the event of an instructor's emergency or unexpected absence, course updates and instructions will be communicated via Canvas and MST University email. If needed, class sessions may be rescheduled, moved online.
- If you have special requests or concerns about COVID-19, please feel free to let me know.

Course Schedule



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Week 1: Introduction of the course
- Week 2: Secure System Design and Principles
- Week 3: Malware (Virus, Worm, Trojan) [homework 1]
- Week 4: Operating Systems Hardening and Buffer Overflow Attacks
- Week 5: [Tuesday, Feb 17 Spring Career Fair] Buffer Overflow Attacks and hands-on solo assignment 1 (Please bring your PC)
- Week 6: Protection via separation
- Week 7: Virtualization (JAVA Sandbox and Virtual Machines) + Midterm review [homework 2]
- Week 8: Midterm (Midterm close-book exam, 1-page A4 cheat-sheet is allowed) + [Spring recess Thursday, March 12]
- Week 9: Client-State Manipulation
- Week 10: [Spring Break]
- Week 11: Reverse engineering, Database security, and Web security
- Week 12: Authentication and Access controls [homework 3]
- Week 13: Firewalls and Intrusion Detection and hands-on solo assignment 2 (Please bring your PC)
- Week 14: Cryptography
- Week 15: Transport Layer Security SSL and TLS [homework 4]
- Week 16: Course review + AI security Talk + Final Exam (Final close-book exam: 1-page A4 cheat-sheet is allowed)

Why this course?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Computer security has become part of the world's critical infrastructure. We are dependent upon network, OS system, and software as we are on electricity, running water, and automobiles.
- Hackers attempt to find and exploit computer security vulnerabilities to cause trouble and damage.
 - Millions of computers are infected and compromised to form botnets to cause massive denial-of-service attack.
 - known weaknesses are exploited to gain control of the target machines or to introduce viruses, worms, or Trojan horses.
 - Computers are intruded and millions of passwords are leaked.

Why this course (cont'd)?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Where are those vulnerabilities from?

In the past, most programmers just want to get job done and they don't consider security. Consequently, computer security has been developed and widely used, with many known vulnerabilities and unknown vulnerabilities to be discovered by attackers

Why this course (cont'd)?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- This course aims to teach you common computer security vulnerabilities and network-based threats, so that you are not writing vulnerabilities into your code.
- This course will provide you with enough background for you to develop a good intuition about what might be secure and what might not be secure.
- Typical attacks and vulnerabilities will be discussed to provide you the practical guidelines for computer security

Security Is Holistic

- Physical Security
- Technological Security
 - Application Security
 - Operating System Security
 - Network Security
- Policies & Procedures
- All three required



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Physical Security



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Limited access to physical space to prevent asset theft and unauthorized entry
- Protecting against information leakage and document theft
- Ex: Dumpster Diving – gathering sensitive information by sifting through the company's garbage

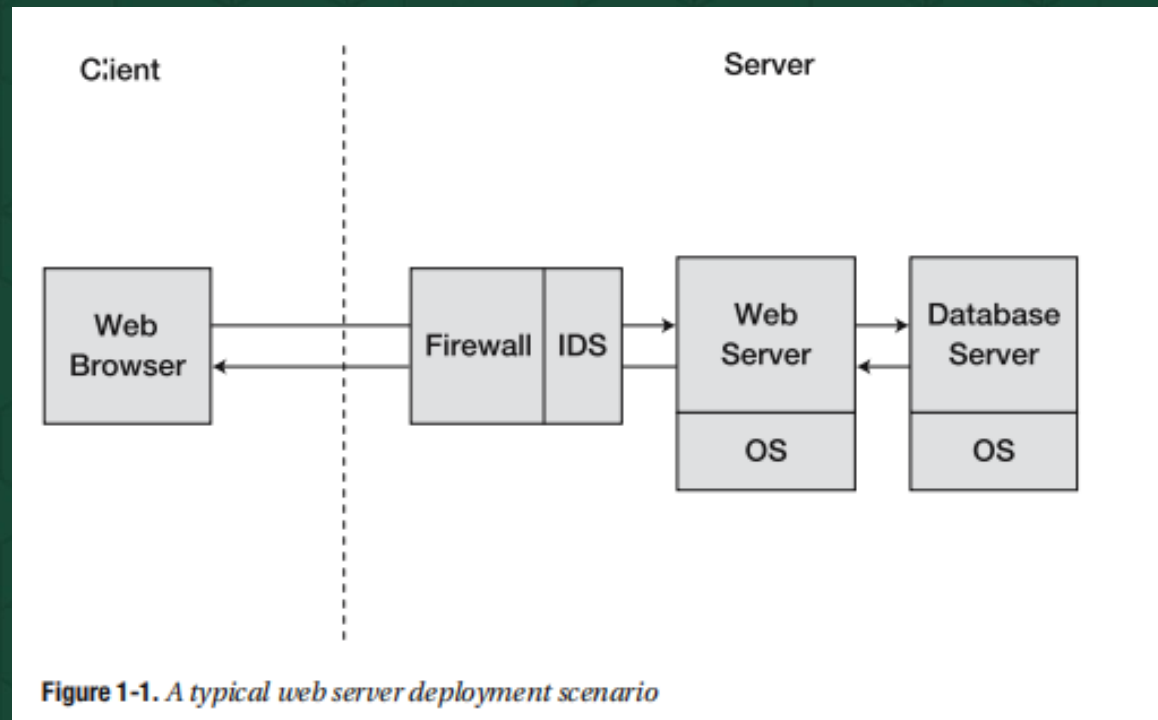
Application Security

- No flaws in identity verification process
- Configure server correctly
 - Local files
 - Database content
- Interpret data robustly



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Web Server & Browser Example



OS & Network Security

- Apps (e.g., servers) use OS for many functions
- OS kernel code likely contains vulnerabilities
 - Regularly download patches to eliminate (e.g., Windows update for critical patches.
- Network Security: mitigate malicious traffic
 - Tools: Firewalls & Intrusion Detection Systems
- Common vulnerability exploit (CVE) website
 - <https://cve.mitre.org/>



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Policies & Procedures



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Guard sensitive corporate information
- Ex: Social engineering attack - taking advantage of unsuspecting employees (e.g., attacker gets employee to divulge his username & password)
- Employees need to be aware, be educated to be somewhat paranoid and vigilant

Security Concepts

- Authentication
- Authorization
- Confidentiality
- Data / Message Integrity
- Accountability
- Availability
- Non-Repudiation



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Archetypal Characters

- Alice & Bob — "good guys"
- Eve — a "passive" eavesdropper
- Mallory — an "active" eavesdropper
- Trent, the person who is trusted by Alice & Bob



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Authentication

- Identity Verification
- How can Bob be sure that he is communicating with Alice?
- Three General Ways:
 - Something you know (i.e., Passwords)
 - Something you have (i.e., Tokens)
 - Something you are (i.e., Biometrics)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Something you KNOW



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Example: Passwords
 - Pros:
 - Simple to implement
 - Simple for users to understand
 - Cons:
 - Easy to crack (unless users choose strong ones)
 - Passwords are reused many times
- One-time Passwords (OTP): different password used each time, but it is difficult for a user to remember all of them

Something you HAVE



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- OTP Cards (e.g., SecureID): generates new password each time user logs in
- Smart Card: tamper-resistant, stores secret information, entered into a card-reader e.g. ATM Card
- Strength of authentication depends on difficulty of forging

Something you ARE



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Biometrics



- Pros: "raises the bar"
- Cons: false negatives/positives, social acceptance, key management
 - false positive: authentic user rejected
 - false negative: impostor accepted

Final notes



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Two-factor Authentication: Methods can be combined (i.e., ATM card & PIN)
- Who is authenticating who?
 - Person-to-computer?
 - Computer-to-computer?
- Three types (e.g., SSL, TLS):
 - Client Authentication: a server verifies a client's identity
 - Server Authentication: a client verifies a server's identity
 - Mutual Authentication (Client & Server)

Authorization



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Checking whether a user has permission to conduct some action
- Identity vs. Authority
- Is a "subject" (Alice) allowed to access an "object" (open a file)?
- Access Control List: mechanism used by many operating systems to determine whether users are authorized to conduct different actions

Access Control Lists (ACLs)



- Set of three-tuples
 - <User, Resource, Privilege>
 - Specifies which users are allowed to access which resources with which privileges
- Privileges can be assigned based on roles (e.g., admin)

Table 1-1. *A Simple ACL*

User	Resource	Privilege
Alice	/home/Alice/*	Read, write, execute
Bob	/home/Bob/*	Read, write, execute

Table 1-2. *A User-Role Mapping*

User	Role
Alice	Administrator, Programmer
Bob	Backup Operator, Programmer

Table 1-3. *A Role-Based ACL*

Role	Resource	Privilege
Backup Operator	/home/*	Read
Administrator	/*	Read, write, execute

Access Control Models

- ACLs used to implement these models
- Mandatory: computer system decides exactly who has access to which resources
- Discretionary (e.g., UNIX): users are authorized to determine which other users can access files or other resources that they create, use, or own
- Role-Based (Non-Discretionary): user's access & privileges determined by role



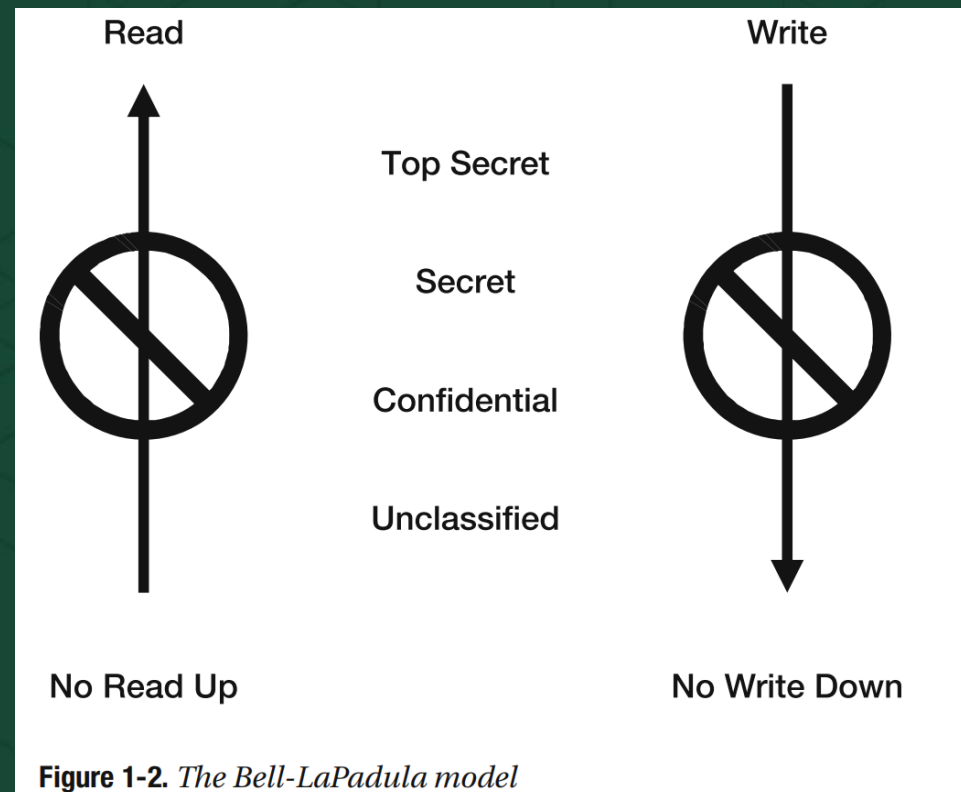
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Bell-LaPadula Model

- Classifications:
 - Top Secret, Secret, Confidential, and Unclassified



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



Confidentiality

- Goal: Keep the contents of communication or data on storage secret
- Example: Alice and Bob want their communications to be secret from Eve
- Key -- a secret shared between Alice & Bob
- Sometimes accomplished with
 - Cryptography, Steganography, Access Controls, Database Views



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Message/Data Integrity



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Data Integrity = No Corruption
- Man in the middle attack: Has Mallory tampered with the message that Alice sends to Bob?
- Integrity Check: Add redundancy to data/messages
- Techniques:
 - Keyed hashing (MD5, SHA-1, ...),
 - Message Authentication Codes (MACs)

Accountability

- Able to determine the attacker
- Logging & Audit Trails
- Requirements:
 - Secure Timestamping (OS vs. Network)
 - Data integrity in logs & audit trails
 - Otherwise, an attacker can cover their tracks



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Availability

- Uptime, Free Storage
 - Ex. Dial tone availability, System downtime limit, Web server response time
- Solutions:
 - Add redundancy to remove single point of failure
 - Impose "limits" that legitimate users can use
- Goal of DoS (Denial-of-Service) attacks is to reduce availability
 - Malware used to send excessive traffic to victim site
 - Overwhelmed servers can't process legitimate traffic



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Non-Repudiation

- Undeniability of a transaction
- Alice wants to prove to Trent that she did communicate with Bob
- Generate evidence / receipts (digitally signed statements)

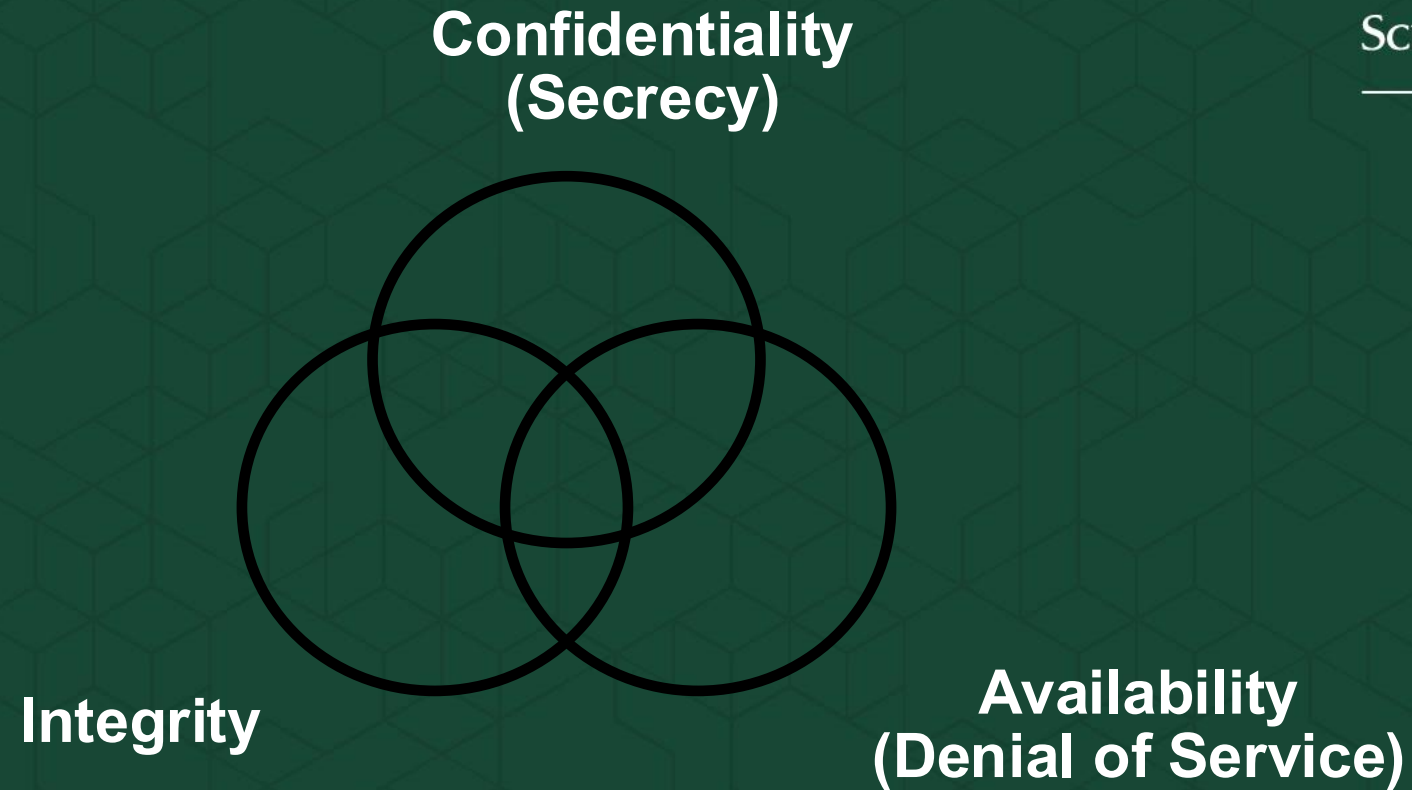


MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Security Objectives



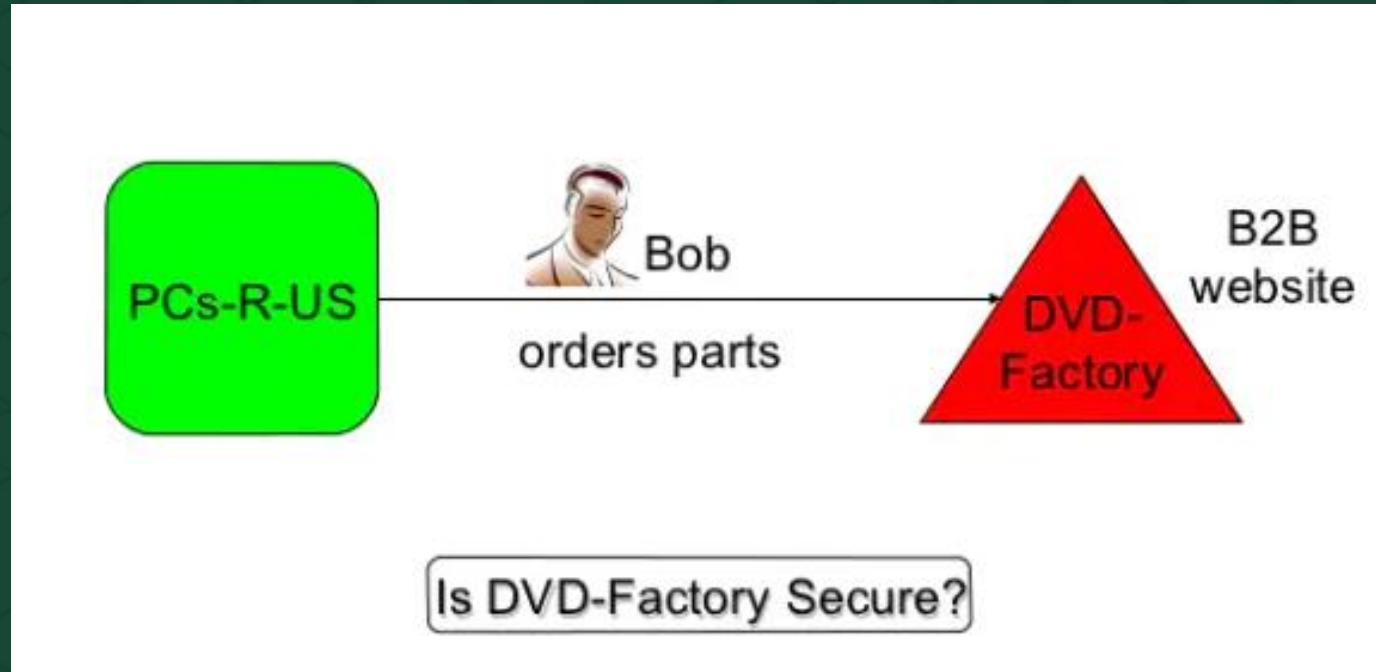
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



Concepts at Work



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

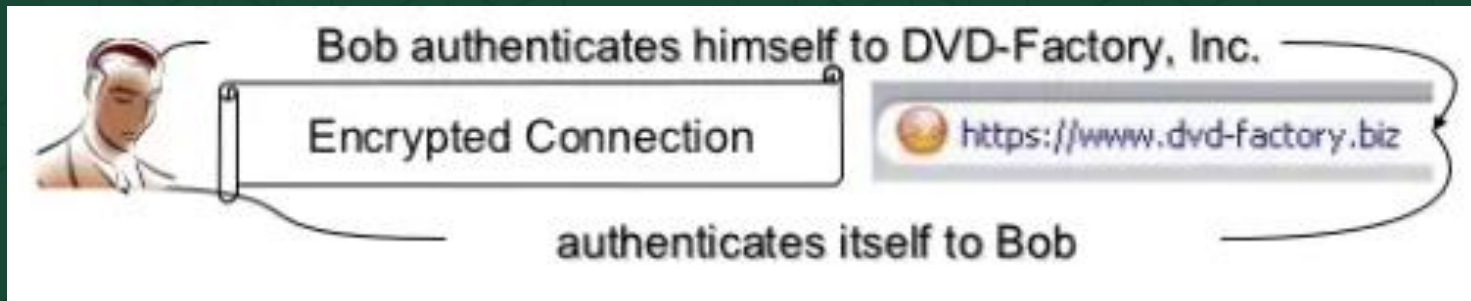


Concepts at Work (2)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Availability:
 - DVD-Factory ensures its web site is running 24-7
- Authentication:



- Confidentiality:
 - Bob's browser and DVD-Factory web server set up an encrypted connection

Concepts at Work (3)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Authorization:
 - DVD-Factory web site consults DB to check if Bob is authorized to order widgets on behalf of PCs-R-Us
- Message / Data Integrity:
 - MACs are included in each packets exchanged
- Accountability:
 - DVD-Factory logs that Bob placed an order for Sony DVD-R 1100
- Non-Repudiation:
 - Hard to achieve in this example

Security by Obscurity

- Security by obscurity
 - If we hide the inner workings of a system, it will be secure
- More and more applications open their standards (e.g., TCP/IP, 802.11)
- Widespread computer knowledge and expertise



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Security by Legislation

- Security by legislation says that if we instruct our users on how to behave we can secure our systems
- For example
 - Users should not share passwords
 - Users should not write down passwords
 - Users should not type in their password when someone is looking over their shoulder
- User awareness and cooperation is important, but cannot be the principal focus for achieving security

Summary

- Technological Security In Context
- Seven Key Security Concepts
- Security goals



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —